

THE TRACE SELF-ASSESSMENT

Score Your Organization's AI Governance in 10 Minutes

By Shikirra • @ShiDoesCyber • Creator of the TRACE Methodology
Mapped to NIST AI RMF 1.0 and the NIST Generative AI Profile (AI 600-1)

HOW THIS WORKS

Five actions. Three questions each. Score every question 0-3, then total each letter.

Think of it like a health checkup: the point isn't a perfect score - it's knowing which system needs attention first. **Your lowest-scoring letter is your biggest exposure.** Start there.

THE SCALE

Score	Level	What it looks like
0	NONE	No visibility, no controls, nobody owns it
1	AD HOC	Individual efforts exist, nothing is documented
2	DEFINED	Documented process, inconsistent execution
3	MANAGED	Enforced, logged, and reviewed on a cadence

T

TRACK

Know what your agents are doing.

NIST AI RMF: MAP 5.1 • MEASURE 2.7 • MANAGE 4.1

T1. Can you produce a complete list of every AI agent operating in your environment - including what systems each can touch?

0 • 1 • 2 • 3

T2. If an agent took a destructive action last Tuesday, could you reconstruct what it did, when, and why from logs?

0 • 1 • 2 • 3

T3. Is prompt injection (direct and indirect) in your penetration testing scope and threat models?

0 • 1 • 2 • 3

TRACK subtotal:

____ / 9

R

RESTRICT

Scope access like a service account.

NIST AI RMF: GOVERN 1.2 • GOVERN 6.1 • MANAGE 2.2

R1. Is AI agent access provisioned through a formal process based on documented business need - the way you'd provision a service account?

0 • 1 • 2 • 3

R2. Do agents default to read-only, with write/delete access granted only by explicit exception?

0 • 1 • 2 • 3

R3. Is agent access reviewed and recertified on a set cadence (at least quarterly)?

0 • 1 • 2 • 3

RESTRICT subtotal:

____ / 9

A

AUDIT

Know what your AI was trained on and where your data goes.

NIST AI RMF: MAP 1.5 • MAP 4.1 • GOVERN 6.1 • GOVERN 6.2

A1. Do your vendor risk assessments ask what LLM powers each AI product - including wrappers (e.g., Copilot runs GPT-4 and Claude underneath)?

0 • 1 • 2 • 3

A2. Do you know, for every approved AI tool, whether your inputs are used to train or fine-tune models?

0 • 1 • 2 • 3

A3. Do you have data protection agreements (or equivalent) covering AI subprocessors for tools that touch sensitive data?

0 • 1 • 2 • 3

AUDIT subtotal:	_____ / 9
-----------------	-----------

C

CONFIRM

Gate every irreversible action.

NIST AI RMF: **MANAGE 1.3 • MANAGE 2.3 • MEASURE 2.6**

C1. Is human approval technically required - not just requested in a prompt - before any agent takes an irreversible action (delete, send, deploy, purchase)?

0 • 1 • 2 • 3

C2. Are agent sessions time-boxed and logged like privileged access sessions?

0 • 1 • 2 • 3

C3. Do you test your own guardrails - red-teaming agents to see if restrictions actually hold under long sessions and adversarial content?

0 • 1 • 2 • 3

CONFIRM subtotal:	_____ / 9
-------------------	-----------

E

EXPOSE

Surface the shadow AI already in your environment.

NIST AI RMF: GOVERN 1.1 • GOVERN 1.6 • GOVERN 4.1 • MAP 1.1

E1. Have you run AI tool discovery in the last six months - employee surveys, OAuth grant logs, SSO logs, browser extensions, expense reports?

0 • 1 • 2 • 3

E2. Do you maintain a living inventory of approved AI tools, with a data classification matrix defining what data can go where?

0 • 1 • 2 • 3

E3. When you find unsanctioned tools, do you investigate *why* employees chose them and provide a sanctioned alternative - rather than just banning?

0 • 1 • 2 • 3

EXPOSE subtotal:

____ / 9

YOUR TRACE SCORE

Letter	Action	Your Score	Priority
T	TRACK	___ / 9	
R	RESTRICT	___ / 9	
A	AUDIT	___ / 9	
C	CONFIRM	___ / 9	
E	EXPOSE	___ / 9	
TOTAL		___ / 45	

Mark your lowest letter as **Priority 1**. That's where your next incident lives.

WHAT YOUR TOTAL MEANS

0-11 - Exposed.

You're operating the way PocketOS was the day before the deletion. The good news: the first 10 points are the cheapest to earn. Start with EXPOSE (you can't govern what you can't see) and CONFIRM (gate the irreversible).

12-24 - Reactive.

Controls exist but they're informal - held together by individual diligence rather than process. One departure or one busy quarter and they evaporate. Document what's working, then enforce it.

25-36 - Defined.

You have a real program. Your gaps are now about consistency and evidence - can you *prove* the controls ran? Focus on logging, cadenced reviews, and closing your lowest letter.

37-45 - Managed.

You're ahead of nearly everyone. Your work now is keeping pace: new agents, new tools, and new attack techniques arrive monthly. Re-run this assessment quarterly.

THE ONE-WEEK STARTER

One move per letter

T	Pick your highest-privilege agent. Run a one-hour threat modeling session: what's the worst thing it could do autonomously?
R	Audit one agent's permissions against actual need. Revoke what isn't justified.
A	Add three questions to your vendor assessment template: What LLM? Trained on what? Is our data used for training?
C	Turn on human-approval mode for destructive actions on one agent. Just one. Prove the workflow.
E	Pull your OAuth grant logs. Count the AI tools you didn't know about.

The TRACE Methodology was created by Shikirra (@ShiDoesCyber) and is mapped to the NIST AI Risk Management Framework 1.0 and the NIST Generative AI Profile (AI 600-1). Incident references: Dark Reading (April-May 2026), Reuters/Bloomberg (2023). For TRACE workshops and implementation support: shidoescyber.com

© ShiDoesCyber LLC. Free to use and share with attribution.